

WEB APPLICATION PENETRATION TEST REPORT

****Project:** Password Store Web Application**

****Assessment Type:** Authenticated Black-Box Penetration Test**

****Methodology:** OWASP Testing Guide v4**

****Tester:** Prem Kr Sharma**

****Test Window:** January 2026**

****Classification:** Confidential**

1. EXECUTIVE SUMMARY

This assessment identified systemic failures in authentication, authorization, and session management. Successful attack chaining enables account takeover, cross-user data exposure, and server-side request exploitation. The weaknesses represent significant risk to user data confidentiality, system integrity, and business trust.

****Overall Risk Rating: CRITICAL****

2. SCOPE

- Target: Web Application & REST APIs
- Access Level: Authenticated user testing
- Out of Scope: Infrastructure, source code review, and third-party services

3. METHODOLOGY

Testing followed OWASP Testing Guide v4 with manual exploitation techniques, request tampering, and abuse simulation.

****Tools Used:** Burp Suite, Browser DevTools, Manual HTTP manipulation**

4. SEVERITY DISTRIBUTION

| Severity | Count |

|-----|-----|

| Critical | 2 |

High	6
Medium	1
Low	2

5. DETAILED VULNERABILITY FINDINGS

Finding 1 — User Enumeration via Forgot Password

****Severity:**** High

****CVSS:**** 7.5 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N)

****Endpoint:**** POST /rest/user/security-question

****Description****

The endpoint reveals account existence through inconsistent server responses.

****Steps to Reproduce****

1. Submit non-existent email
2. Observe 304 response
3. Submit valid email
4. Observe 200 response with JSON

****Proof of Concept****

...

POST /rest/user/security-question

{ "email": "valid@test.com" }

→ 200 OK

...

****Business Impact****

Enables mass account discovery, phishing, and targeted attacks.

****Remediation****

Return uniform responses and implement rate limiting.

Finding 2 — Missing Rate Limiting on Login

****Severity:**** High

****Endpoint:**** POST /rest/user/login

****Description****

Unlimited login attempts allowed.

****Steps to Reproduce****

Attempt multiple logins without delay.

****Impact****

Brute-force and credential stuffing risk.

****Remediation****

Implement throttling, CAPTCHA, and lockout policies.

Finding 3 — IDOR — Basket Access

****Severity:** High**

****Description****

Basket IDs are not validated for ownership.

****Steps to Reproduce****

Modify basket ID to access another user's basket.

****Impact****

Unauthorized data exposure.

****Remediation****

Enforce server-side ownership checks.

Finding 4 — Session Not Invalidated After Logout

****Severity:** High**

****Description****

Session token remains valid after logout.

****Steps to Reproduce****

Use token after logout to access endpoints.

****Impact****

Persistent unauthorized access.

****Remediation****

Token revocation and rotation.

Finding 5 — SSRF via Profile Image URL

****Severity:**** High

****Description****

Server fetches attacker-supplied URLs.

****Impact****

Internal network probing and service discovery.

****Remediation****

URL allowlisting and IP filtering.

Finding 6 — Broken Access Control on Feedbacks API

****Severity:**** Critical

****Description****

Feedback records accessible and deletable across users.

****Impact****

Data exposure and permanent data loss.

****Remediation****

RBAC and ownership validation.

Finding 7 — IDOR — Complaints

****Severity:**** High

****Description****

Complaint resources lack ownership validation.

Finding 8 — User Enumeration via Registration

****Severity:**** High

****Description****

Registration endpoint discloses existing emails.

Finding 9 — Information Disclosure — User ID

****Severity:**** Low

****Description****

Internal user ID exposed in response.

Finding 10 — Stack Trace Disclosure

****Severity:**** Medium

****Description****

Unhandled exceptions expose internal paths.

6. ATTACK CHAIN

Enumeration → Brute Force → Account Access → IDOR → Session Persistence → SSRF

7. FINAL VERDICT

The application is not suitable for production until remediation of critical and high-risk vulnerabilities is completed.